

감사결과 처분요구서

처분요구 번호	2023-116	처분요구일자	2023-12-28
처 분 종 류	시정(일반), 권고, 개선, 통보		
관 계 부 서	★★처(☆☆팀), ◇◇실(◆◆팀)		
제 목	개인정보 통제절차 강화 필요		

지 적 내 용

1. 업무 개요

★★처(☆☆팀)는 인천국제공항공사(이하 “공항공사”라 한다) 경영정보 시스템을 구축하여 운영하고 있으며, 경영정보시스템 내 ‘인사관리’ 및 ‘보수관리’에서는 직원의 인적사항, 근태, 보수, 복리후생 정보 등 개인 정보를 조회하고 다운로드 할 수 있다.

◇◇실(◆◆팀), ○○처(AA팀, BB팀), ●●실(CC팀)은 업무수행에 필요한 정보사용을 위해 경영정보시스템 내 ‘인사관리 및 ‘보수관리’ 접근 권한을 부여받아 사용하고 있으며, 접근 권한을 부여받은 직원은 공항공사 직원에 대한 인사 및 보수정보에 대해 조회 및 파일 생성이 가능하다.

2. 관계법령(규정) 및 판단기준

「개인정보 보호법」 제32조 제1항에 따르면 개인정보파일을 운용하는 경우 운영근거 및 목적, 정보항목, 정보처리 방법 및 보유기간 등에 대해 개인정보 보호위원회에 등록하도록 되어 있으나, ‘공공기관의 내부적 업무처리만을 위하여 사용되는 개인정보파일’은 같은 법 제32조 제2항 제4호에 따라 예외대상으로 인정되어 등록 및 공개대상에서 제외되어 왔다.

그런데 2023. 9. 15.자로 「개인정보 보호법」이 개정되어 내부 업무처리에 사용되는 개인정보파일에 대해서도 등록 및 공개 대상에 포함하도록 하고 있어 내부에서 활용되고 있는 공항공사 직원에 대한 개인정보도 관리체계를

강화할 필요성이 높아졌다.

「개인정보 보호법」 제29조에서는 개인정보 보호를 위해 접속기록 보관 등 안전성 확보에 필요한 조치를 하도록 하고 있으며, 개인정보 보호위원회 고시(제2023-6, 2023. 9. 22.) 「개인정보의 안전성 확보조치 기준」(이하 “보호위원회 고시”라 한다)을 통해 개인정보 안전조치에 대한 최소한의 기준을 정하고 있다.

보호위원회 고시 제5조 및 제8조에 따르면 개인정보처리시스템에 대한 접근 권한은 최소 범위로 차등 부여되어야 하며, 개인정보처리시스템에 대한 접속기록은 1년 이상 보관·관리하도록 하고 있다. 또한 접속기록 등에 대해 월 1회 이상 점검하고, 개인정보 다운로드가 확인된 경우 사유를 반드시 확인하도록 하고 있다.

그리고 「개인정보 보호법」 제21조 제1항에 따르면 보유기간 경과, 목적 달성 등 개인정보가 불필요하게 된 경우 지체 없이 파기하도록 하고 있으며, 보호위원회 고시 제5조에 따르면 개인정보취급자 또는 개인정보취급자의 업무가 변경되었을 경우 지체 없이 개인정보처리시스템의 접근 권한을 변경 또는 말소하도록 하고 있다.

3. 감사결과 확인된 문제점

가. 과도한 개인정보 접근 권한 부여

보호위원회 고시에 따르면 개인정보처리시스템에 대한 접근 권한은 최소 범위로 부여하여야 한다.

그런데 ‘인사정보 마스터 접근 권한’ 보유부서를 대상으로 접근 가능한 개별 정보에 대해 실제 사용 여부 및 사용 빈도를 조사한 결과, 일부 과도하게 개인정보 접근 권한이 부여된 사실이 확인되었다.

AA팀은 ‘직원명단’ 정보만 필요하기에 ‘인사정보 마스터 접근 권한’은 사용하지 않고 있고, BB팀은 직원 급여 및 복리후생 업무수행에 필요한

정보만 사용 중에 있으며, CC팀은 비상임 이사 인사발령 및 급여 업무에 필요한 정보만 필요할 뿐 그 외 개인정보는 사용하고 있지 않다.

하지만 ‘인사정보 마스터 접근 권한’은 세부 개인정보별로 접근을 통제하고 있지 않기에 모든 인사 정보에 접근 가능하도록 권한이 부여되고 있었다.

따라서 불필요하게 개인정보 접근 권한이 부여되어 개인정보가 남용되지 않도록 부서별 업무에 맞게 필요한 정보를 확정하여 최소 수준으로 접근 권한이 부여될 수 있도록 업무별 접근 권한 부여기준 마련이 필요하다.

나. 개인정보 ‘접속기록 관리 기능’ 미흡

현재 공항공사 경영정보시스템 내 ‘인사관리’ 시스템 접속기록은 1년 동안 기록·보관되고 있으나, 개인정보 다운로드 이력은 기록하여 저장하는 기능이 구현되어 있지 않다.

또한 ‘인사관리’ 시스템에서 조회한 개인정보를 파일로 생성하여 다운로드 시 사용목적 등을 기입하도록 하는 기능이 부재하여 ‘인사관리’ 접근 권한을 부여받은 자는 별다른 정보를 남기지 않고도 개인정보를 다운로드하여 사용할 수 있다.

직원에 대한 인사정보는 내부 업무처리를 위해 활용되지만 인사관리에 포함된 정보도 개인정보이기에 외부에서 취득한 개인정보 관리수준에 준하도록 철저하게 관리되어야 함이 마땅하다.

따라서 ‘인사관리’ 시스템에서 인사정보를 반출하는 경우 보호위원회 고시를 준용하여 접속기록을 1년 이상 보관하도록 하고, 접속기록에는 접속자 계정, 접속일시, 수행업무 등 충분한 정보가 확보되도록 시스템 기능을 보완할 필요가 있다.

다. 개인정보 관리 통제절차 강화 필요

☆☆팀은 인사발령으로 ‘인사관리’ 접근 권한이 불필요하게 된 경우 인사발령 기준으로 ‘인사관리’ 접근 권한을 자동 회수하고 있다.

더불어 ‘인사관리’ 접근 권한 보유부서를 대상으로 확인한 결과, 인사발령 후 업무 목적을 사유로 보유한 개인정보는 전부 파기하고 있다고 하였으나, 이행여부 확인절차는 부재하다.

한편, 업무 목적을 사유로 인사정보가 필요한 부서에서 ‘인사관리’ 접근 권한 보유부서에 개인정보 자료 제공을 요청하는 경우, 사용 목적, 필요한 정보 내용을 전자메일로 요청받아 필요 사유 및 정보 제공 범위를 파악한 후 자료 요청자에게만 정보를 제공하고 있으나, 별도 이력관리는 되고 있지 않다.

또한 개인정보 자료 제공 시 목적 외 사용을 하지 않고, 목적 달성 후 자료를 파기하도록 안내하고 있으나, 정보를 제공받는 부서에서도 책임 의식을 갖고 개인정보 안전 조치를 철저히 이행하도록 관리할 필요가 있다.

관계부서(관련자) 등 의견 및 검토결과

★★처(☆☆팀)는 감사결과를 받아들이면서 별다른 의견을 제시하지 않았다.

◇◇실(◆◆팀)은 제공한 자료에 대해서는 목적 외 사용 금지 및 사용 후 파기 요청을 안내하고 있으며, 타 부서에서 요청하여 제공한 개인정보에 대해 안전하게 관리해야 할 책임은 요청부서에 있다는 의견을 제시하였다.

하지만 정보 제공 부서에서도 제3자에게 제공하는 정보에 대한 이력관리가 필요하며, 정보를 제공받는 부서로 하여금 개인정보 안정성 확보를 위한 조치 이행의 책임이 있음을 명확히 전달하는 절차가 마련될 필요가 있다.

조치할 사항

① 사장(★★처장)은 ‘인사정보 마스터 접근 권한’을 보유한 부서에 대해 필요한 개인정보 항목 및 사용 빈도 등을 종합 검토하여 접근 가능한 정보 범위를 최소화하도록 조치하고, 세부 개인정보별 접근 통제가 가능하도록

접근 권한 부여 기능을 개선하시기 바랍니다. (시정)

② 사장(★★처장)은 향후 개인정보에 접근이 가능한 시스템에 대해 과도하게 권한이 부여되지 않도록 부서별 업무에 따라 필요한 세부 개인정보를 확인하여 접근 권한 부여 기준을 마련하시기 바랍니다. (권고)

③ 사장(★★처장)은 경영정보시스템(SAP) 내 ‘인사관리’ 시스템을 통한 개인정보 접속 및 다운로드 기록을 1년 이상 보관하도록 하고, 개인정보 반출 시 책임 추적을 위해 사용 목적 및 기간 등 충분한 접속기록 정보가 확보되도록 시스템 기능을 보완하시기 바랍니다. (개선)

④ 사장(◇◇실장)은 인사발령에 따라 개인정보 접근 권한이 불필요해진 경우 업무상 필요 사유로 개별 보유하고 있는 개인정보 자료를 파기하도록 철저히 관리하시기 바라며, 개인정보 자료 요청에 따라 정보제공 시, 제공 이력을 관리하고, 개인정보 안전조치 이행 및 책임 소지를 명확히 할 수 있도록 공식적인 개인정보 제공 절차를 마련하시기 바랍니다. (통보)

인천국제공항공사 상임감사위원

직 인 생 략